Cybersecurity Audit Report | Phase 2

Topology-led NIS2 and NIST CSF risk assessment

Shareholder-friendly security findings for the Packet Tracer network. This report focuses on architecture, segmentation, identity, service exposure, and resilience because the project evidence does not prove authenticated access to every device.

OVERALL AUDIT SCORE

67/100

Moderate residual risk. The design is strong for a lab and demonstrates clear security thinking, but it is not production-ready.

EXECUTIVE DECISION

Accept as learning project, not as a production security baseline

The network shows VLAN segmentation, a DMZ, ACLs, SSH management, logging, NTP, and server separation. The highest business risks are weak credentials, incomplete proof of centralized identity, and single points of failure.

AUDIENCE

Leadership, CISO, CTO

EVIDENCE

Topology, packet file, reports, logs

FRAMEWORK LENS

NIS2, NIST CSF 2.0, CIS

RISK VIEW

Business impact first

Executive Summary

Moderate

WHAT WORKS

Segmentation is visible.
Users, internal servers, storage, management, and the DMZ are separated into VLANs.

WHAT WORRIES US

Identity and resilience.
Weak lab credentials and single core/edge devices create high risk in a real business.

EVIDENCE BOUNDARY

Architecture review.
Not all devices could be proven through live authenticated access; risk is based on topology and saved evidence.

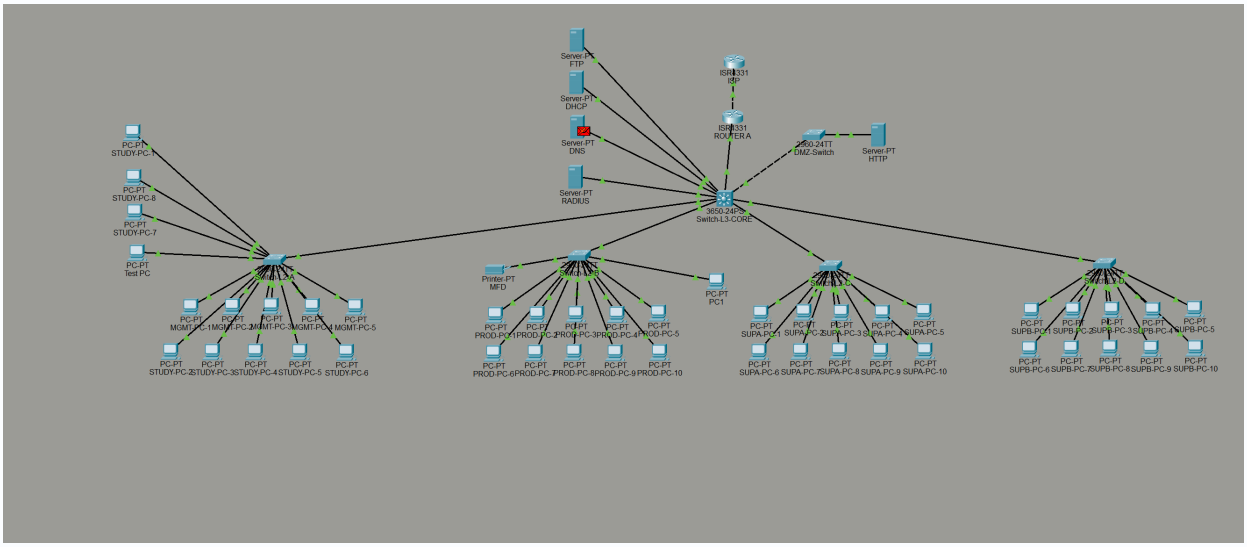
Top Business Findings

1	**Single Layer 3 core switch.** One core failure can stop inter-VLAN routing, service access, and management reachability.	High
2	**Single edge router.** Internet, NAT, and inbound DMZ paths depend on one edge device.	High
3	**Weak credentials on network and FTP services.** Observed values include admin/admin, cisco/cisco, 0000, cisco123, and other lab secrets.	High
4	**Centralized AAA/RADIUS not fully proven.** The server exists, but end-to-end enterprise identity control is not demonstrated.	High
5	**ACLs show good intent but need tightening.** Broad permits increase lateral movement risk if a workstation or server is compromised.	Medium

Board-level message: the design is directionally good because it separates trust zones, but it needs stronger identity proof, better failover, and tighter access rules before it could be defended as a production network under NIS2-style governance.

Network Topology And Trust Boundaries

The topology is the strongest available evidence. The audit therefore evaluates security by how traffic should flow between trust zones and where one device failure or one account compromise could affect the business.



User VLANs

VLAN 10, 20, 30, and 40 separate departments and reduce uncontrolled lateral movement.

DMZ

HTTP server 192.168.10.195 is isolated in VLAN 60, reducing exposure of internal networks.

Internal services

DNS 192.168.10.130, DHCP 192.168.10.131, and RADIUS 192.168.10.132 sit in VLAN 70. Service access must stay controlled.

Critical dependency

Switch-L3-CORE and ROUTER A are central control points with no proven high availability.

Main Assets

ASSET	ROLE	RISK MEANING
Switch-L3-CORE	All VLAN gateways, inter-VLAN routing, ACL enforcement	High dependency
ROUTER A	Internet edge, NAT, inbound path to DMZ	High dependency
DMZ HTTP server 192.168.10.195	Public-facing web service	Isolated zone
FTP/storage server 192.168.10.226	Storage and file service	Weak credentials
RADIUS server 192.168.10.132	Central identity attempt	Verify AAA

Control Status Dashboard

CONTROL AREA	OBSERVED POSTURE	NIS2 / NIST RELEVANCE	STATUS
Governance and risk	Findings are documented and mapped, but final device evidence has limits.	NIS2 management accountability; NIST CSF Govern	Partial
Asset and topology inventory	Major devices, VLANs, servers, gateways, and roles are listed.	NIST CSF Identify; NIST SP 800-53 CM-8	Good
Network segmentation	DMZ, internal services, storage, user VLANs, and management VLAN are separated.	NIST SP 800-53 SC-7; CIS; NIS2 risk controls	Good
Privileged access	SSH and AAA attempts exist, but weak passwords are documented.	NIST SP 800-53 AC/IA; NIST CSF Protect	Weak
Monitoring and detection	Syslog and NTP are present, but SIEM, retention, alerting, and incident workflow are not proven.	NIST CSF Detect; NIS2 incident handling	Partial
Business continuity	No proven redundant core, edge router, DNS, DHCP, or RADIUS server.	NIS2 business continuity; NIST CSF Recover	Weak

NIST CSF 2.0 Readout

Govern: risk is identified but operational ownership is not shown.

Identify: topology and asset roles are documented.

Protect: segmentation exists; identity controls need stronger proof.

Detect: basic logging exists, but alerting is not mature.

Respond/Recover: incident and failover processes are not proven.

NIS2-style Management View

NIS2 expects risk management, access control, incident handling, business continuity, and management accountability. This Packet Tracer design demonstrates several security measures, but the weak identity evidence and single points of failure are the areas that would be hardest to defend to leadership.

Prioritized Findings

ID	FINDING	EVIDENCE	BUSINESS IMPACT	SEVERITY
F1	Single Layer 3 core switch	All VLAN gateways and inter-VLAN routing depend on Switch-L3-CORE.	One failure can interrupt departments, services, storage, and management.	High
F2	Single edge router	ROUTER A owns internet routing, NAT, and the inside/outside boundary.	External connectivity and DMZ access have one main dependency.	High
F3	Weak network credentials	Evidence includes admin/admin, cisco, cisco123, 123456789, and related lab secrets.	Attackers can use valid accounts to bypass segmentation.	High
F4	FTP service has weak users and broad permissions	FTP users admin/admin, cisco/cisco, securityasiye/0000 all have RWDNL permissions.	File integrity and network images can be modified or deleted.	High
F5	AAA/RADIUS not fully proven	RADIUS server exists, but Packet Tracer evidence does not prove complete centralized authentication.	Harder to enforce user lifecycle, accountability, and MFA-style control.	High
F6	Broad ACL permits	ACL summaries include broad service and DHCP permits.	Compromise in one zone may have more movement paths than necessary.	Medium
F7	Basic logging only	Syslog and NTP point to 192.168.10.130; SIEM and alert workflow are not shown.	Incidents may be harder to detect, investigate, and report.	Medium
F8	Service concentration	DNS server also acts as syslog and NTP target.	One server outage affects multiple operational controls.	Medium
F9	Printer VLAN unclear	VLAN 50 appears but final addressing is inconsistent.	Documentation gap; printer access could be misconfigured.	Low
F10	DMZ isolation	HTTP server 192.168.10.195 is placed in VLAN 60 with inbound ACL intent.	Reduces chance that public web exposure reaches internal networks.	Positive

Access Matrix Summary

SOURCE	EXPECTED ACCESS	SHOULD NOT ACCESS	STATUS
Internet / ISP side	DMZ HTTP server 192.168.10.195 on TCP 80 and 443.	Internal user VLANs, management IPs, server VLAN, storage VLAN.	Controlled
Internet / ISP side	DNS UDP 53 appears permitted by ACL.	All other inbound traffic due to deny ip any any.	Narrow later
Network switches	RADIUS server 192.168.10.132 for AAA intent.	Unauthenticated management from user, DMZ, or internet zones.	Verify
User VLANs 10/20/30/40	DNS, DHCP, RADIUS, FTP/storage, DMZ web, and internet where ACLs permit.	Direct department-to-department access.	Broad rules
DMZ HTTP server	Public HTTP/HTTPS access and gateway 192.168.10.193.	Internal server, storage, and management networks.	Good design
FTP/storage server 192.168.10.226	Only approved user VLANs where FTP/storage is required.	DMZ-originated or unrestricted access.	Weak users

Credential Evidence

CREDENTIAL / SECRET	WHERE OBSERVED	RISK
admin / admin	Local network-device administrator and FTP evidence	Weak
admin / cisco	Local device login / console-style lab credential	Weak
admin / 123456789	Local admin password attempt	Weak
RADIUS key cisco123	Shared secret evidence	Weak
FTP cisco / cisco	FTP screenshot with RWDNL permissions	Weak
FTP securityasiye / 0000	FTP screenshot with RWDNL permissions	Weak

Why this matters: segmentation is useful only if administrators and services cannot be accessed with simple passwords. Credential weakness is the fastest path from a lab design issue to a real compromise.

Recommended Decisions

1. **Replace weak credentials and remove shared accounts.** Use unique secrets, password vaulting, and no default-style values. — Now
2. **Prove centralized AAA/RADIUS or document the Packet Tracer limitation.** For production, require RADIUS/TACACS+ integrated with identity management and keep a protected break-glass account. — Now
3. **Tighten ACLs to least privilege.** Replace broad permits with specific source, destination, and port rules. — Next
4. **Design redundancy for the core and edge.** Add a second Layer 3 core, redundant uplinks, gateway failover, and redundant edge/firewall design in the real-world recommendation. — Next
5. **Improve monitoring and evidence retention.** Add log retention, alerting for failed logins and ACL denies, and an incident escalation workflow. — Plan

Final Audit Grade

ASSESSMENT AREA	WEIGHT	SCORE	REASON
Topology and asset understanding	10%	8/10	Major devices, VLANs, and roles are documented.
Segmentation and DMZ	20%	17/20	Strong separation of users, DMZ, servers, storage, and management.
Access control and ACLs	15%	10/15	Good intent, but broad rules need refinement.
Identity and credentials	20%	8/20	Weak credentials and incomplete AAA evidence are major issues.
Monitoring and response	10%	7/10	Syslog/NTP exist; alerting and retention are not proven.
Resilience	15%	5/15	Core and edge are single points of failure.
Compliance defensibility	10%	8/10	Risks are mapped clearly to NIST, CIS, CyFun, and NIS2 concepts.
Total	**100%**	**67/100**	**Moderate residual risk**

Evidence Limitation Statement

This audit is based on the Packet Tracer topology, the final packet file, command logs, screenshots, and the existing phase 2 reports. The project does not fully allow authenticated testing of every device in the same way a real production audit would. Therefore, this report does not claim complete live validation of all device configurations.

Where the evidence is strong, the report says the control is present. Where the evidence is incomplete, the report marks the item as verification required. This makes the report defensible: it communicates risk without inventing proof.

Evidence Used

EVIDENCE SOURCE	USE IN REPORT
Network Design Main final version.pkt	Primary Packet Tracer design file.
viewable logical topology.png	Main visual evidence for topology, zones, and dependencies.
Final report_wip.md	Findings, FTP/RADIUS evidence, ACL evidence, and grading baseline.
Phase_2_Packet_Tracer_Network_Report.md	Device inventory, VLAN plan, routing, services, and compliance mapping.
Screen_Recording_2026-04-22_Command_Log.md	Command-level supporting evidence where available.

Closing Conclusion

The Packet Tracer network demonstrates a good security architecture for a learning project: segmented VLANs, DMZ isolation, ACL filtering, SSH management, port security, logging, and time synchronization. The design becomes hard to defend as production-ready because of weak credentials, incomplete AAA proof, broad ACLs, and central single points of failure. Fixing those issues would materially improve NIS2 and NIST CSF alignment.